



Instituto Politécnico Nacional

Escuela Superior de Cómputo



Gobierno de IT | Governance IT

Análisis de Riesgos

Equipo 3:

Camacho Zavala Ricardo

García García Aram Jesua

Rodríguez Martínez Erick Damián

7CV4

ACTIVO			VALORACIÓN					
ID_PROCESO	ID_ACTIVO	ACTIVO DE INFORMACIÓN	C	I	D	TOTAL	VALOR 1	VALOR 2
TAC_PROC_01	ACT_HW_01	Servidor de Datos	1	5	5	11	Alto	3
	ACT_SW_01	Entorno de Ejecución Python 3.12+	3	5	3	11	Alto	3
	ACT_SE_01	Almacenamiento en la Nube	1	1	5	7	Medio	2
TAC_PROC_02	ACT_HW_02	Firewall Perimetral	1	2	5	8	Medio	2
	ACT_SW_02	Base de Datos (SQLite/PostgreSQL)	5	5	2	12	Alto	3
	ACT_SE_03	Servicio de Internet Dedicado	1	1	5	7	Medio	2
TAC_PROC_03	ACT_HW_03	Equipos de Cómputo (x6)	5	3	3	11	Alto	3
	ACT_SW_04	Navegador Web o Cliente	5	2	1	8	Medio	2
	ACT_SE_02	Certificado SSL/TLS de la CA	5	5	4	14	Critico	4

VULNERABILIDADES	AMENAZAS
Falta de automatización o desconocimiento en el manejo manual de los directorios de resguardo de llaves en Linux.	Error de configuración operativa.
Falta de validación de firmas y hashes (checksum) en el archivo de requerimientos (requirements.txt).	Código malicioso incrustado en actualizaciones de software.
Dependencia absoluta de un único proveedor en la nube para alojar las copias de seguridad de los logs.	Interrupción o caída de infraestructura externa.
Reglas de acceso (ACLs) mal estructuradas o permisivas en la configuración de red.	Intrusión y ataque de red.
Implementación débil en la validación de firmas dentro del Token JWT al realizar el cruce dinámico de permisos.	Modificación no autorizada de datos.
Ausencia de un enlace de red redundante (Failover) para soportar caídas del ISP primario.	Corte total del servicio de telecomunicaciones.
Carencia de cifrado de disco duro completo a nivel de sistema operativo en las terminales físicas.	Robo o extravío de dispositivo físico.
Aislamiento deficiente de la memoria RAM en el entorno de ejecución del cliente.	Exfiltración de información y espionaje (Malware).
Falta de monitoreo y alertas automatizadas para el control del ciclo de vida y renovación.	Expiración del certificado de seguridad.

EVENTO DE AMENAZA (RIESGO)	CONTROLES
Borrado accidental o sobreescritura de la llave privada maestra del servidor, dejando archivos cifrados irre recuperables.	Borrado accidental o sobreescritura de la llave privada maestra del servidor, dejando archivos cifrados irre recuperables.
Un atacante compromete el repositorio público (PyPi) y el servidor descarga una versión manipulada de la librería.	Fijar versiones exactas de las librerías (pip freeze) y descargar dependencias solo de fuentes confiables.
Inaccesibilidad temporal al repositorio de respaldos, frenando las auditorías de integridad.	Configurar un almacenamiento local redundante (buffer) en el nodo central.
Explotación de puertos abiertos y saturación del puerto 65432 (DDoS).	Implementar el principio de menor privilegio en el firewall y ejecutar auditorías de escaneo.
Escalada de privilegios que permite a un usuario alterar la tabla de permisos en la base de datos.	Reforzar la firma del JWT con HMAC-SHA256 y rotar secretos de autenticación periódicamente.
Daño físico en la fibra óptica que desconecta el Servidor de Datos e impide la validación de Tokens JWT.	Contratar un enlace de internet de respaldo secundario y configurar balanceo (SD-WAN).
El robo de un equipo expone código fuente, credenciales en caché y metadatos sensibles.	Implementar cifrado de disco (BitLocker o LUKS) y contar con software MDM para borrado remoto.
Extracción de la llave KEK en claro o captura de pantalla por un keylogger instalado en el equipo.	Sanitización estricta de las variables en la memoria del navegador y requerir software EDR.
El certificado caduca, provocando el rechazo de conexiones o un ataque Man-in-the-Middle.	Configurar un sistema de monitoreo automático de alertas a 30 y 15 días e implementar HSTS.

Análisis de vulnerabilidades			
Vulnerabilidades	Severidad	Exposición	Valor3
Falta de automatización o desconocimiento en el manejo manual de los directorios de resguardo de llaves en Linux.	3	2	4
Falta de validación de firmas y hashes (checksum) en el archivo de requerimientos (requirements.txt).	3	2	4
Dependencia absoluta de un único proveedor en la nube para alojar las copias de seguridad de los logs.	2	2	3
Reglas de acceso (ACLs) mal estructuradas o permisivas en la configuración de red.	3	3	5
Implementación débil en la validación de firmas dentro del Token JWT al realizar el cruce dinámico de permisos.	3	2	4
Ausencia de un enlace de red redundante (Failover) para soportar caídas del ISP	2	3	4
Carencia de cifrado de disco duro completo a nivel de sistema operativo en las terminales físicas.	2	2	3
Aislamiento deficiente de la memoria RAM en el entorno de ejecución del cliente.	3	3	5
Falta de monitoreo y alertas automatizadas para el control del ciclo de vida y renovación.	3	2	4

Amenazas	Eventos de amenaza	Capacidad	Motivación	Valor4
Error de configuración operativa.	Borrado accidental o sobrescritura de la llave privada maestra del servidor, dejando archivos cifrados irrecuperables.	2	1	2
Código malicioso incrustado en actualizaciones de software.	Un atacante compromete el repositorio público (PyPI) y el servidor descarga una versión manipulada de la librería.	3	3	5
Interrupción o caída de infraestructura externa.	Inaccessibilidad temporal al repositorio de respaldos, frenando las auditorías de	2	1	2
Intrusión y ataque de red.	Explotación de puertos abiertos y saturación del puerto 65432 (DDoS).	2	3	4
Modificación no autorizada de datos.	Escalada de privilegios que permite a un usuario alterar la tabla de permisos en la base	2	2	3
Corte total del servicio de telecomunicaciones.	Daño físico en la fibra óptica que desconecta el Servidor de Datos e impide la validación	2	1	2
Robo o extravío de dispositivo físico.	El robo de un equipo expone código fuente, credenciales en caché y metadatos	2	2	3
Exfiltración de información y espionaje (Malware).	Extracción de la llave KEK en claro o captura de pantalla por un keylogger instalado en el	3	3	5
Expiración del certificado de seguridad.	El certificado caduca, provocando el rechazo de conexiones o un ataque Man-in-the-	2	1	2

Evento de amenaza (Riesgo)	Amenaza	Vulnerabilidad	Probabilidad	Impacto	Riesgo Total
Borrado accidental o sobrescritura de la llave privada maestra del servidor.	2	4	2 (Media)	11	176
Un atacante compromete PyPI y el servidor descarga una librería manipulada.	5	4	1 (Baja)	11	220
Inaccessibilidad temporal al repositorio externo de respaldos.	2	3	2 (Media)	7	84
Explotación de puertos abiertos y saturación del puerto 65432 (DDoS).	4	5	2 (Media)	8	320
Escalada de privilegios que permite alterar la tabla de permisos en la BD.	3	4	1 (Baja)	12	144
Daño físico en la fibra óptica que desconecta el Servidor de Datos (Corte ISP).	2	4	3 (Alta)	7	168
El robo de un equipo expone código fuente, credenciales y metadatos.	3	3	1 (Baja)	11	99
Extracción de la llave KEK en claro o captura de pantalla por un keylogger.	5	5	2 (Media)	8	400
El certificado caduca, provocando el rechazo de conexiones.	2	4	3 (Alta)	14	336

ACTIVO			VALORACIÓN						
ID_PROCESO	ID_ACTIVO	ACTIVO DE INFORMACIÓN	Área Geográfica	Periodo de Afectación	IMPACTO	Cantidad de Infraestructuras Críticas Afectadas	Campos Afectados	INTERDEPEN-DENCIA	CRITICIDAD
TAC_PROC_01	ACT_HW_01	Servidor de Datos	2	1	2	2	1	2	III
	ACT_SW_01	Entorno de Ejecución Python 3.12+	2	1	2	2	1	2	III
	ACT_SE_01	Almacenamiento en la Nube	1	2	2	1	1	1	II
TAC_PROC_02	ACT_HW_02	Firewall Perimetral	2	2	3	2	1	2	III
	ACT_SW_02	Base de Datos (SQLite/PostgreSQL)	2	1	2	1	1	1	II
	ACT_SE_03	Servicio de Internet Dedicado	3	2	4	3	2	4	V
TAC_PROC_03	ACT_HW_03	Equipos de Cómputo (x6)	3	3	5	3	2	4	V
	ACT_SW_04	Navegador Web o Cliente	1	1	1	1	1	1	I
	ACT_SE_02	Certificado SSL/TLS de la CA	2	3	4	2	1	2	IV

IDENTIFICACIÓN DE INFRAESTRUCTURAS CRÍTICAS		
INFRAESTRUCTURAS CRÍTICAS DETECTADAS	GRADO DE CRITICIDAD	CONTROLES A IMPLEMENTAR
Servidor de procesamiento de datos	III	Redundancia y controles físicos
Entorno de Ejecución Python 3.12+ =(ejecución y bibliotecas)	III	Documentación de elementos necesarios y generación de respaldo automático de instalación
Almacenamiento en la Nube para copias de seguridad	II	Renovación y chequeos constantes, revisión del tamaño de almacenamiento periódico
Firewall Perimetral (filtrado de datos por sockets)	III	Control de sesiones y tokens por renovación periódica
Base de Datos (SQLite/PostgreSQL) (cruce de permisos)	II	Respaldos periódicos, generación de bitácoras
Servicio de Internet Dedicado	V	Servicio de respaldo, plan de recuperación inmediata de la red
Equipos de Cómputo (estaciones de trabajo)	V	Adquisición de garantías por cada equipo y mantenimiento periódico
Certificado SSL/TLS de la CA	IV	Renovación periódica, gestión de accesos y de su administración